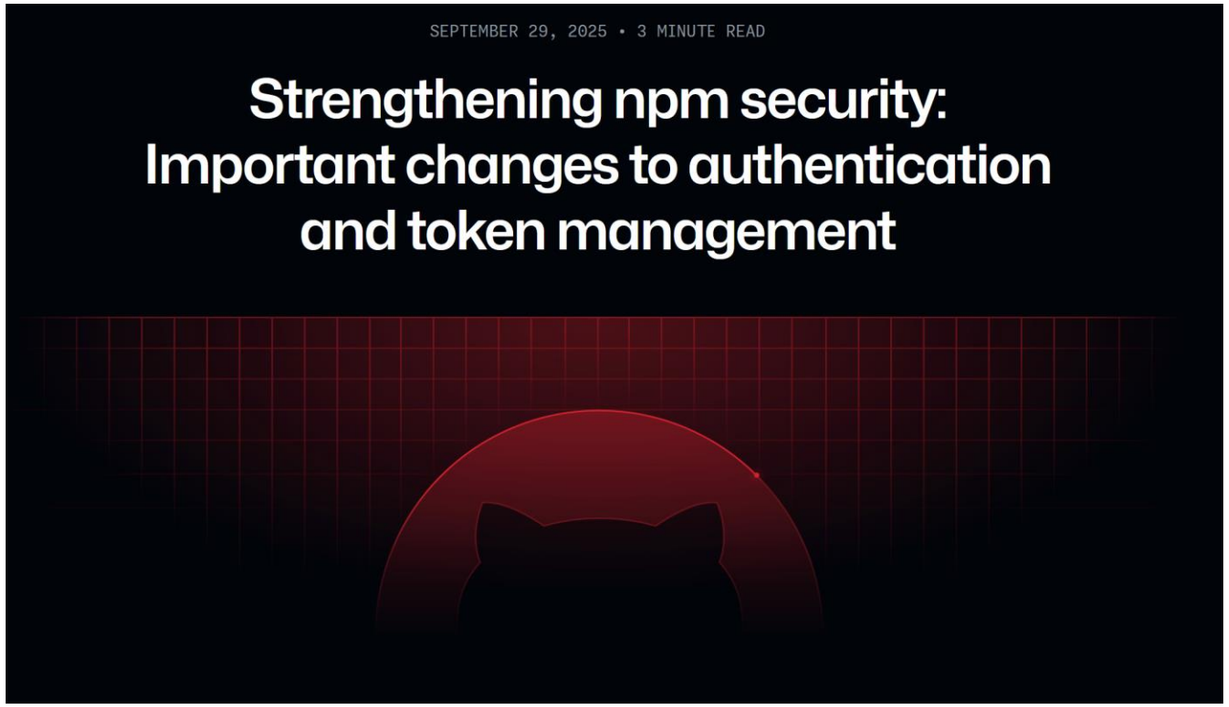
Developer Operations (devops)

Continuous Integration / -deployment

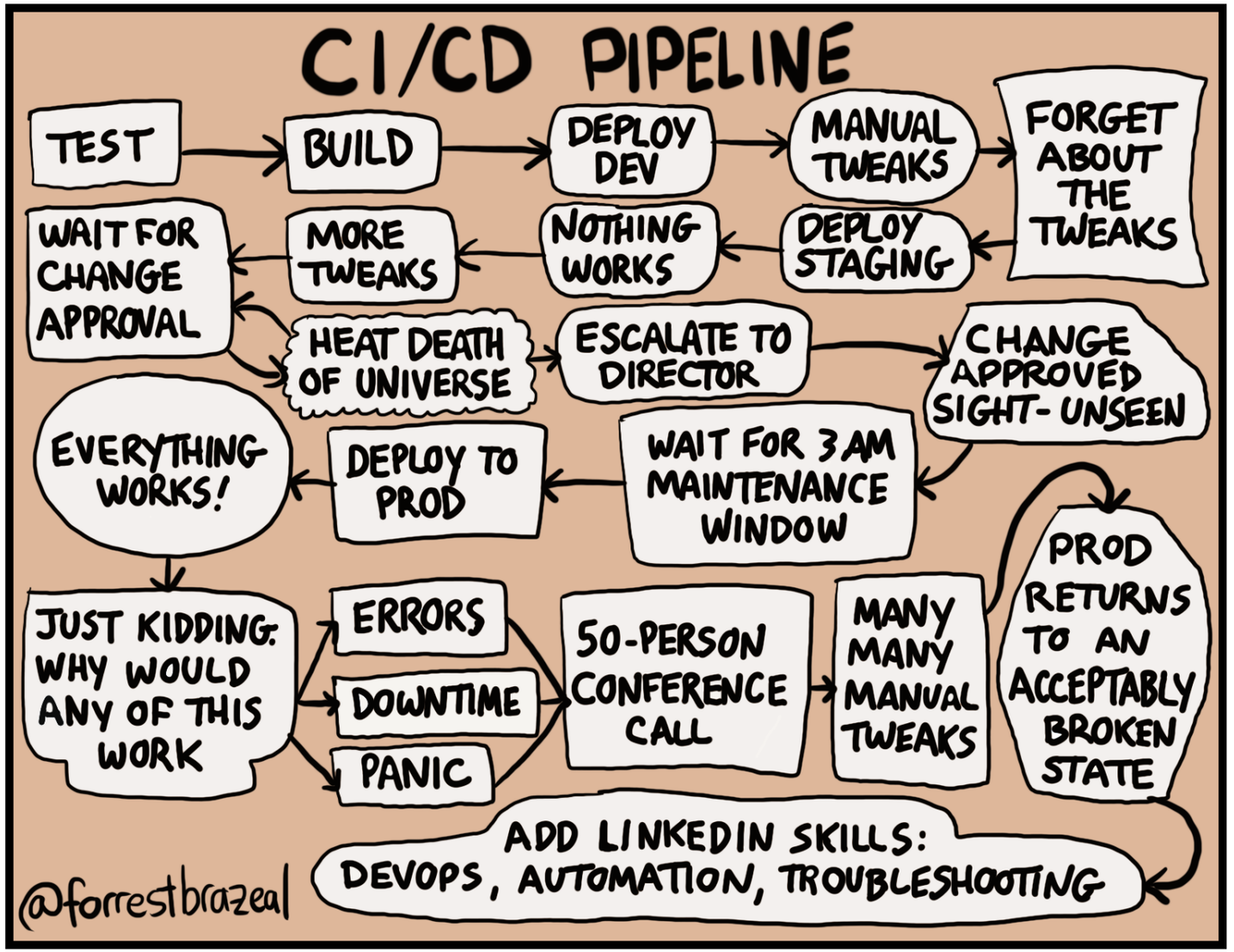
Breaking News - Strengthening npm security

- **Npm access token lifetime limits**
  - A default expiration of seven days, reduced from 30 days.
  - A maximum expiration of 90 days, which used to be unlimited.
- **TOTP retired as 2FA**
  - Passkeys will be used in the future
- **Push towards “trusted publishing (OIDC)”**
  - Currently only supported by GitLab and GitHub

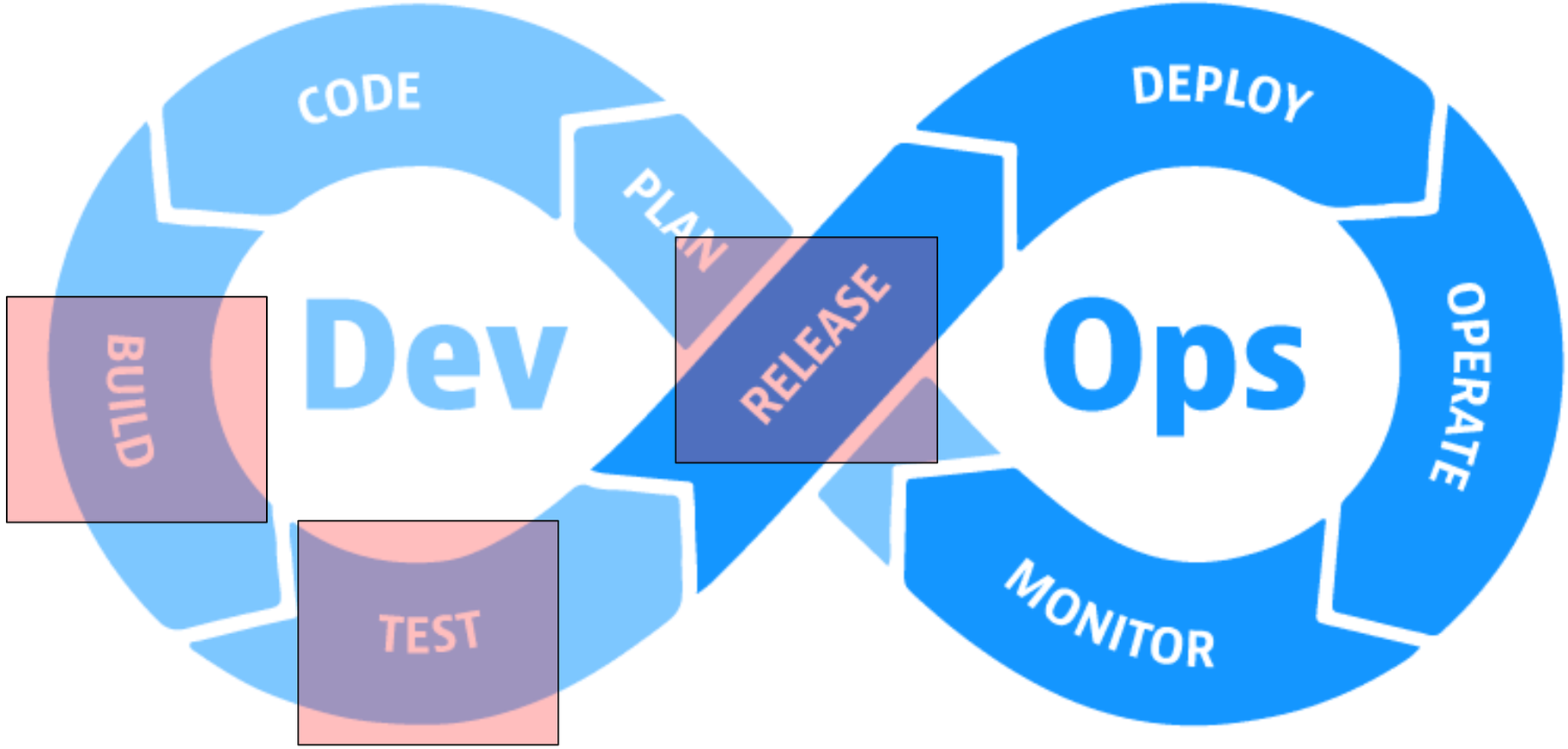


https://github.blog/changelog/2025-09-29-strengthening-npm-security-important-changes-to-authentication-and-token-management/

Building Software and deploying it



Build and Release



Build and Deploy-Pattern

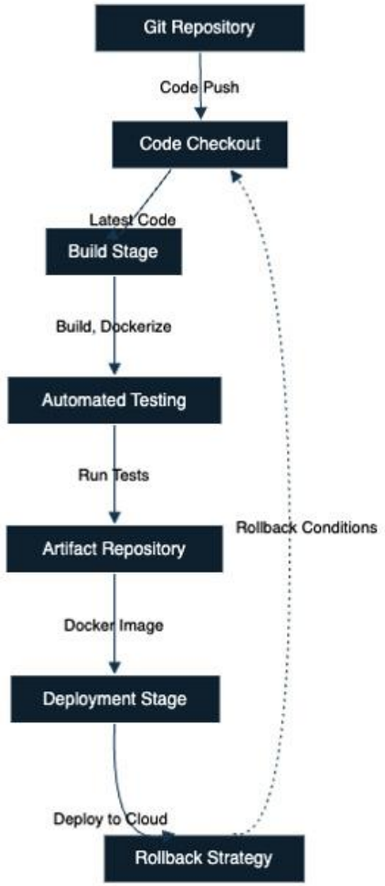
Separate Build and Deploy

→ Increases stability and robustness

→ One artifact for testing and production (stage parity in 12factor methodology)

→ Should base on release-workflow of source code management

→ Focus on Build for today



Example build and deploy model

Application Structure:

1. Source Code Repository:
   - Hosted on Git:.
2. Web Application:
   - A simple Node.js application with an `app.js` file

CI/CD Pipeline:

1. Code Checkout:
   - Triggered on each code push to the GitHub repository
   - Checks out the latest code
2. Build Stage:
   - Tasks:
     - Installs Node.js dependencies
     - Builds the application
     - Creates a Docker image
3. Automated Testing:
   - Tasks:
     - Runs unit tests using a testing framework (for example, Mocha)
4. Artifact Repository:
   - Pushes the Docker image to a container registry (for example, Docker Hub)
5. Deployment Stage:
   - Tasks:
     - Deploys the Docker image to a cloud platform (for example, AWS, Azure, or Google Cloud)
     - May involve creating or updating infrastructure using Infrastructure as Code (IaC) tools
6. Rollback Strategy:
   - Defines conditions for rolling back to a previous version in case of deployment failures

Why to use a Build System?

Independent Platform:

- Single Source of Truth → Source Control
- Single Source of Build → Build System

Defines:

- Build Tool Version
- Guardrails regarding testing / analysis
- Transparency to build process

Why to use a Build System?

Centralized Credential Handling:

Access to all kinds of necessary adjacent toolsets such as:

- Repositories / Registries
- Analysis Platforms (Sonarqube)
- Issue Management
- Additional Testingframeworks
- (Platforms to be provisioned)

Why to use a Build System?

Independent Build Status:

Transparent Status about the build:

- Alignment of Team
- Ability to release (if necessary)
- Status of Tests
- Prioritization of issues
- “Operating Status of the Source”

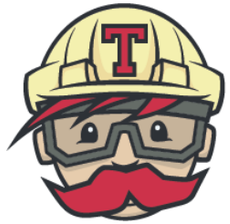
Why to use a Build System?

Increasing the bus factor (also known as the “truck number”):

“How many or few would have to be hit by a truck (or quit) before the project is incapacitated?” – JIM COPLIEN

Bus Factor == 1 → immediate time for action

Modern CI-Systems



Travis CI

GitLab

Jenkins

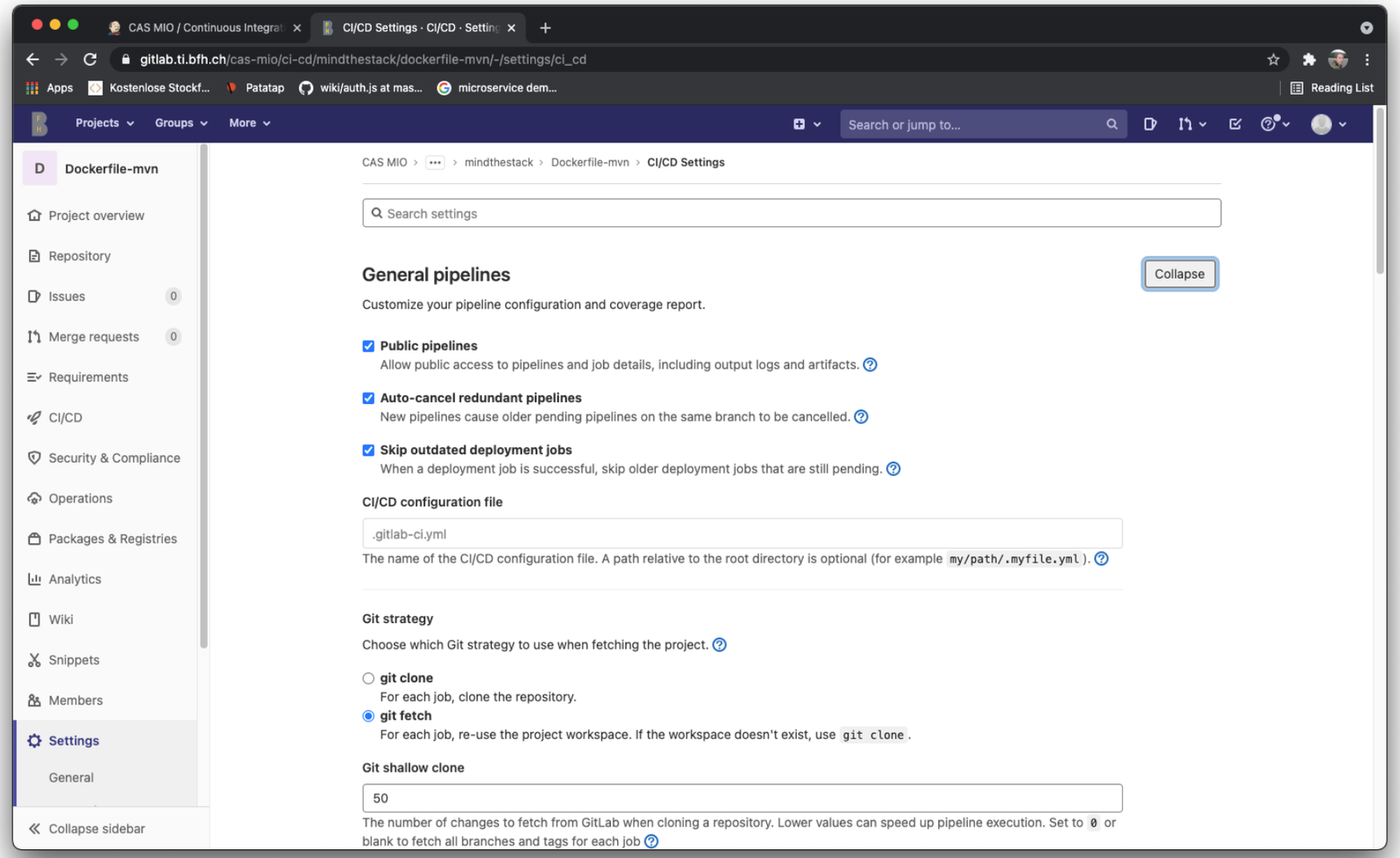
Bamboo

GitHub Actions

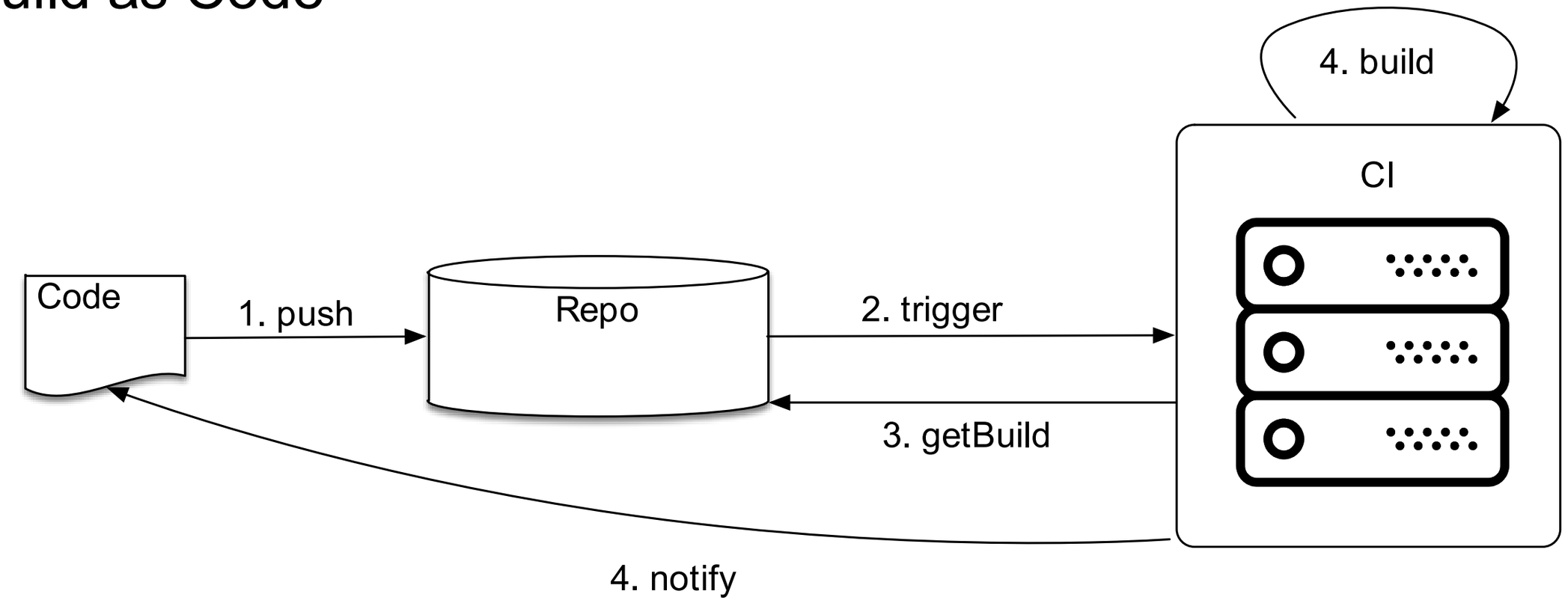
circleci

cruisecontrol

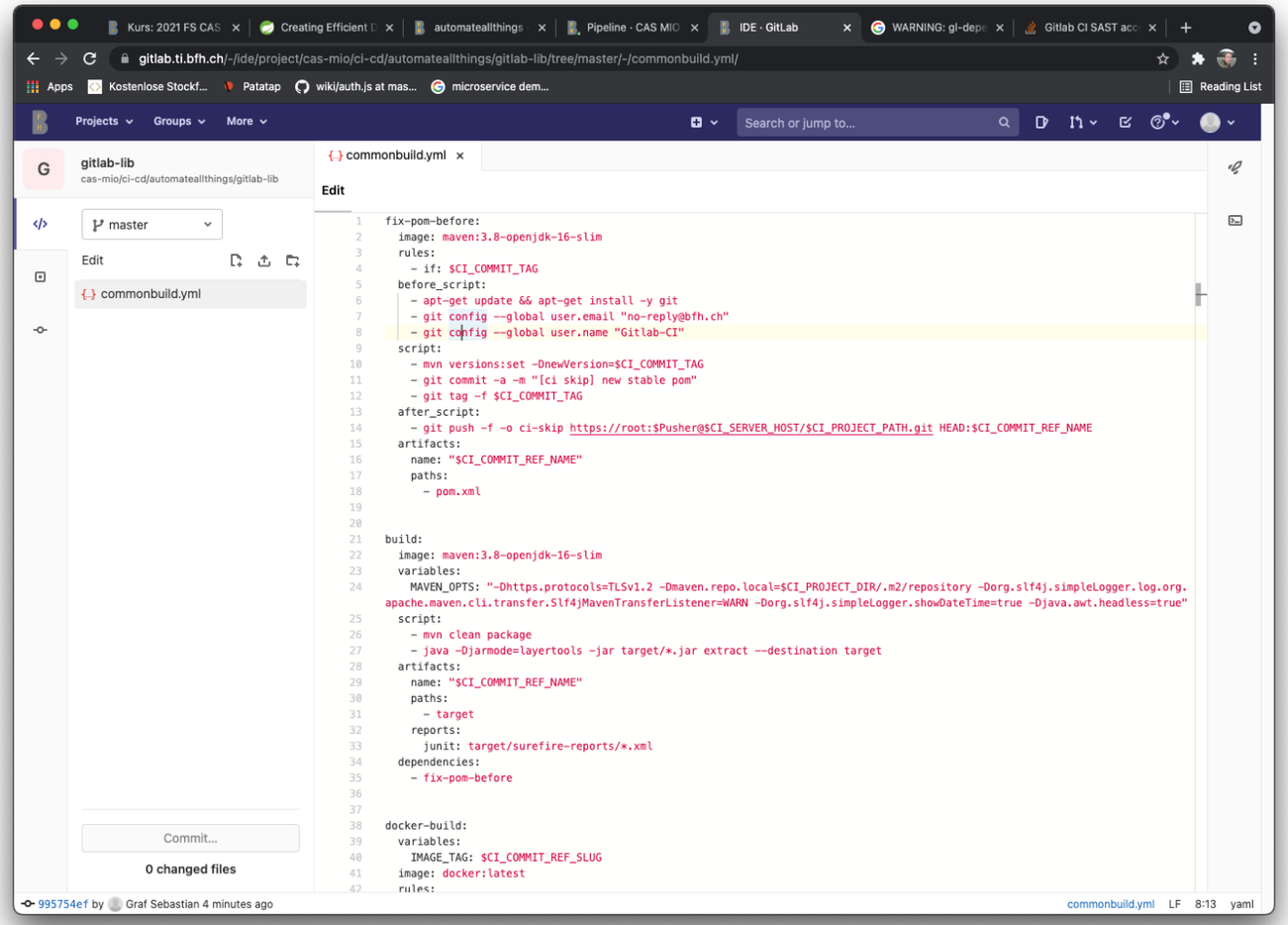
Build as Code, Gitlab



Build as Code

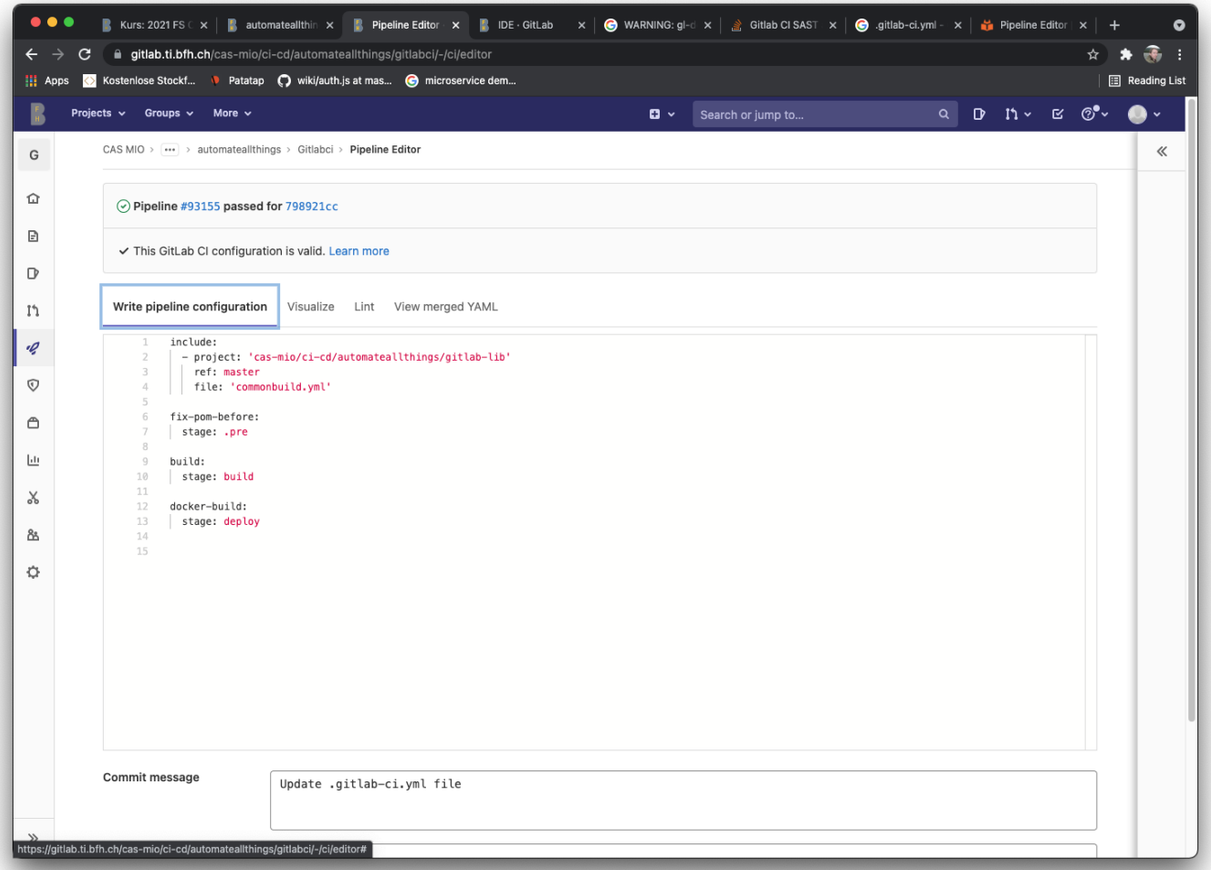


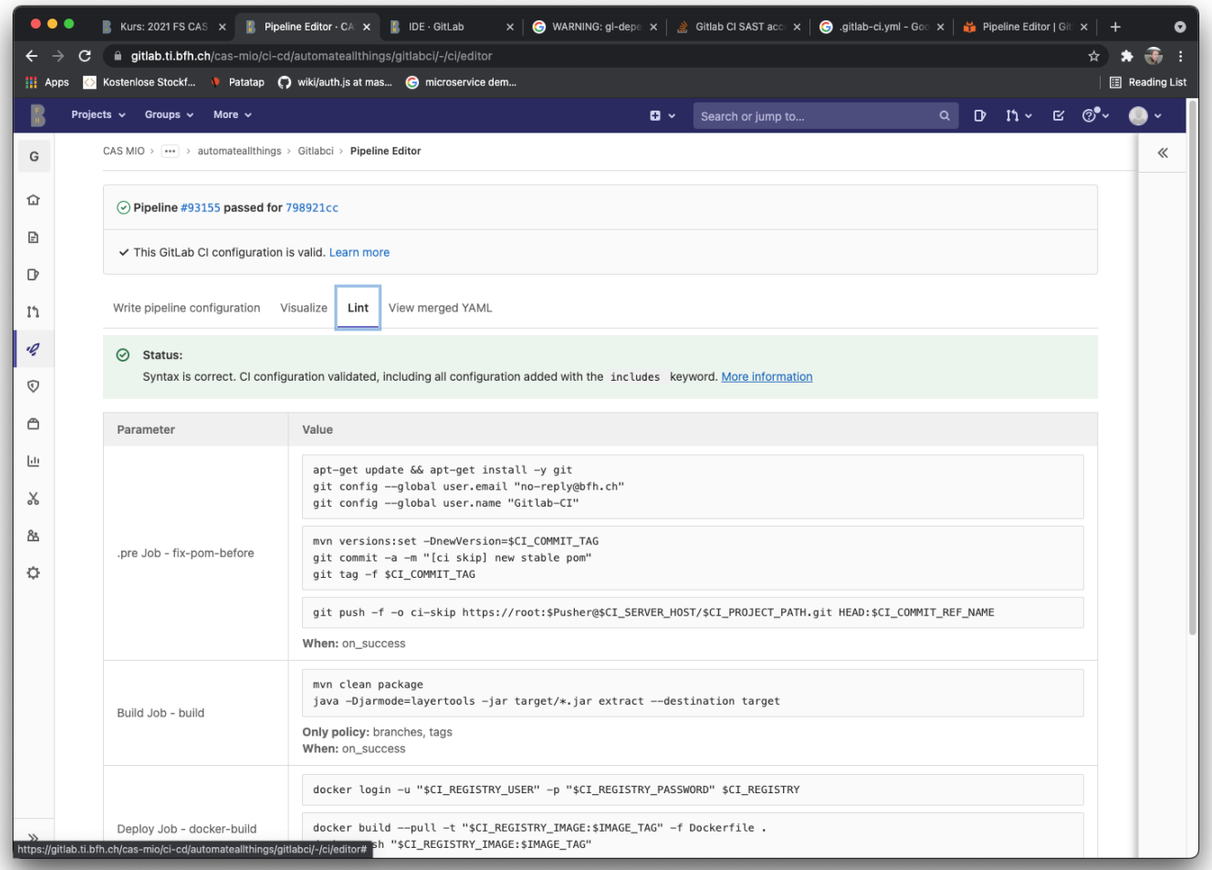
Gitlab Web IDE



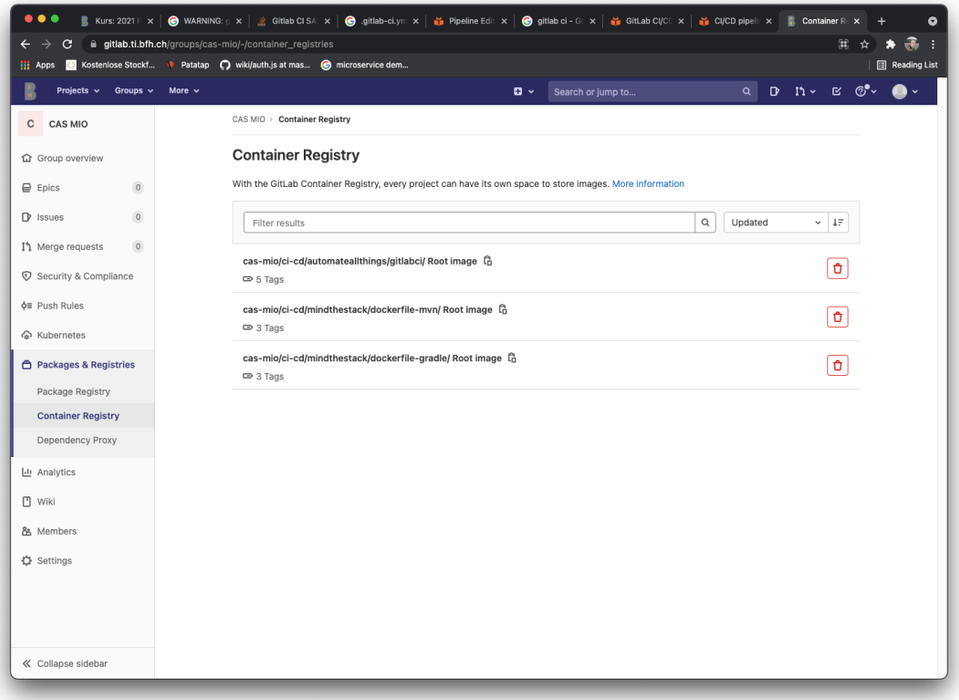
Gitlab-CI Development

DEMO





Gitlab-Registry



- Aggregated View over Projects, Subprojects[0..*], Repositories
- Direct Access via Gitlab-CI
- Credential for pulling is needed
- If you want to mutate a project: clean the registry first

Documentation

- Gitlab Keywork Reference
- https://docs.gitlab.com/ee/ci/pipelines/
- https://docs.gitlab.com/ee/ci/yaml/
- https://docs.gitlab.com/ee/ci/examples/

Pipeline Libraries, Gitlab Components

Templates VS Components:

- Both used for referencing common steps shared between multiple pipelines
- Defined for given steps (might be able to be overridden)

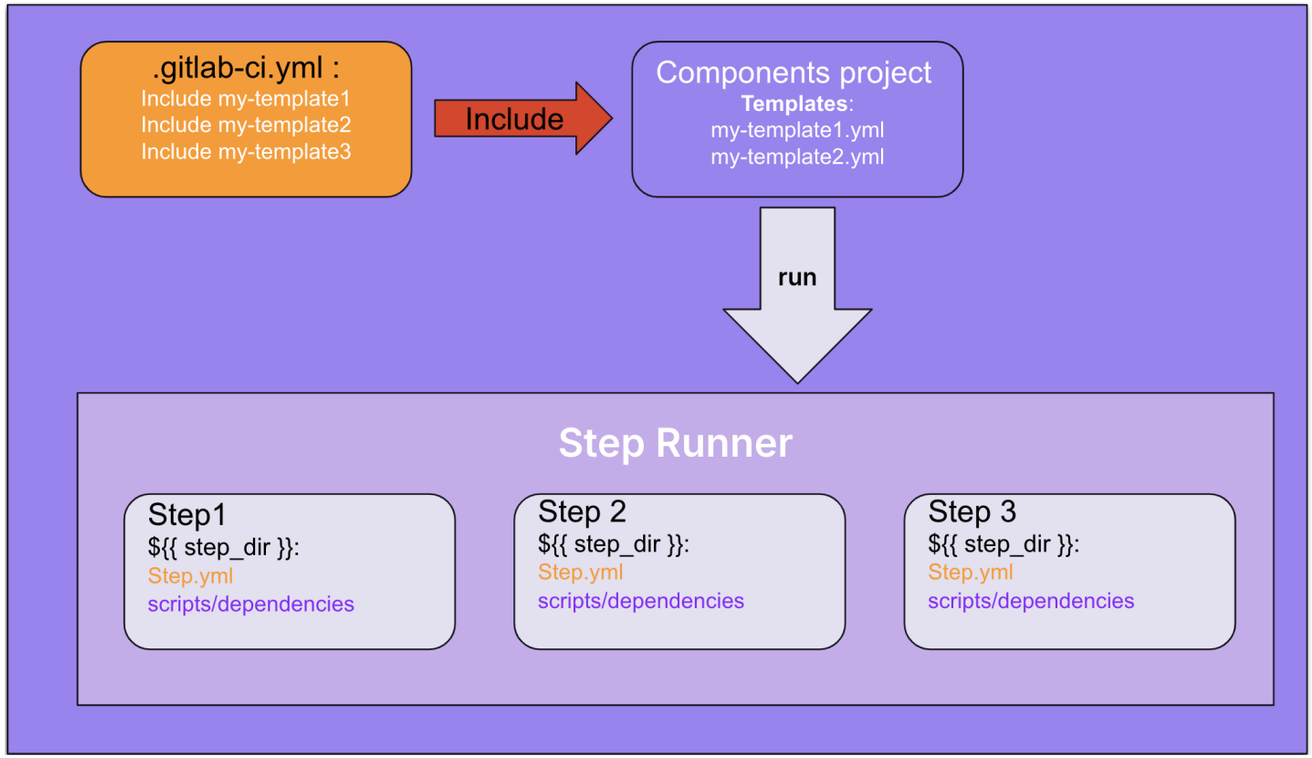
→ DRY-concept

Templates:

- Old but well integrated (several dashboards)
- Parametrization takes place via variables

Components:

- Newer concept with defined parameters
- need to be mirrored / included into components library (CI/CD catalogue)



https://about.gitlab.com/blog/2024/10/16/how-to-include-file-references-in-your-ci-cd-components/

Common Do's and don'ts

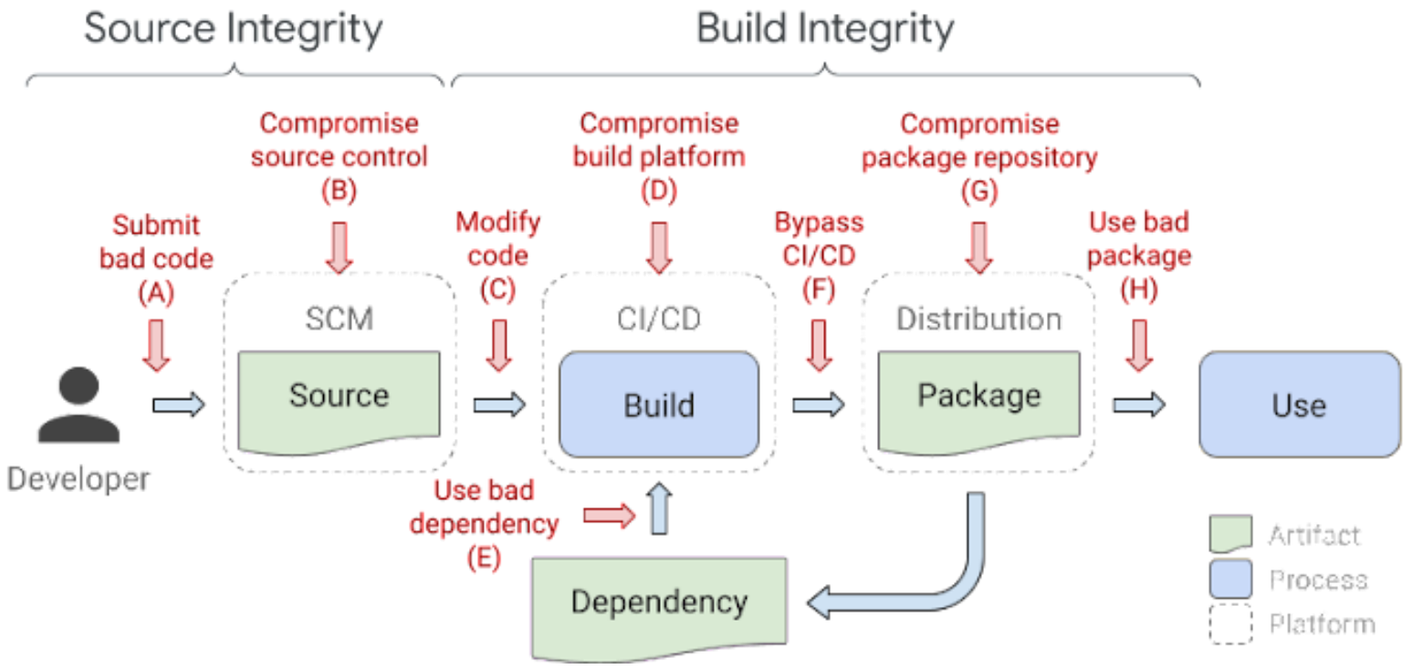
Do's

- Everything in sourcecode
- Do not reinvent the wheel
- Fail fast, if necessary
- Utilize entire internal toolset, variables methods, libs, …
- Keep it simple
- When working with external services…
  - …use time outs
  - make failure optional
- Sketch your build into steps…
  - Which build stage are you using for which step?
  - What can be executed in parallel?
  - Where are artifacts passed between the build steps?

Don'ts

- Beware of conflicts / intransparencies / llifecycle issues when using multiple libraries
- Do not expect everything works as expected
  - Debugging is exhausting
  - Reference literatur / documentation / sourcecode
- Tokens need to be rotated
  - Use your calendar
- Be aware of quotas in build regarding
  - Logs
  - Time
  - Number of Artifacts

Beyond Simple Building, SLSA



		Required at			
Requirement		SLSA 1	SLSA 2	SLSA 3	SLSA 4
Source	Version Controlled		✓	✓	✓
	Verified History			✓	✓
	Retained Indefinitely			18 mo.	✓
	Two-Person Reviewed				✓
Build	Scripted	✓	✓	✓	✓
	Build Service		✓	✓	✓
	Ephemeral Environment			✓	✓
	Isolated			✓	✓
	Parameterless				✓
	Hermetic				✓
	Reproducible				○
Provenance	Available	✓	✓	✓	✓
	Authenticated		✓	✓	✓
	Service Generated		✓	✓	✓
	Non-Falsifiable			✓	✓
	Dependencies Complete				✓
Common	Security				✓
	Access				✓
	Superusers				✓

https://security.googleblog.com/2021/06/introducing-slsa-end-to-end-framework.html

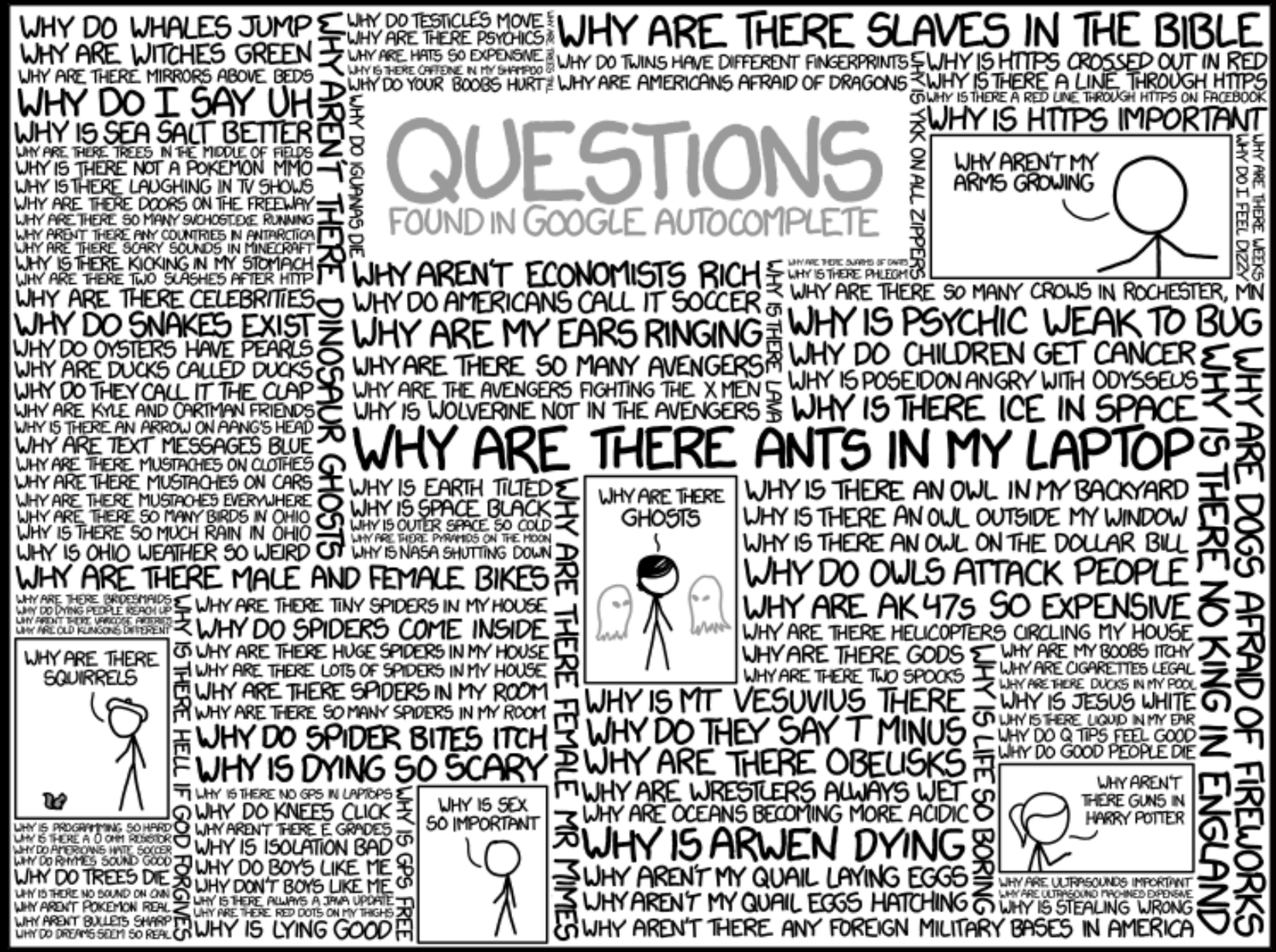
Beyond Simple Building: ChatOps, Dependency Mgmt, …

Automatism extend simple building such as:

- Notifications
- Lifecycle Management of Packages
- Issue Management
- Pull Request Management
- …

Name	Description	Install
auto-approve	Automatically approves and merges PRs matching user-specified configs	install
auto-label	Automatically labels issues and PRs with product, language, or directory based labels	install
blunderbuss	Assigns issues and PRs randomly to a specific list of users	install
cherry-pick-bot	Cherry-pick merged PRs between branches	install
conventional-commit-lint	PR checker that ensures that the commit messages follow conventionalcommits.org style	install
do-not-merge	PR checker that ensures the `do not merge` label is not present	install
failurechecker	Check for automation tasks, e.g., releases, that are in a failed state	install
flakybot	Listen on PubSub queue for broken builds, and open corresponding issues	install
generated-files-bot	PR checker to notify if you are modifying generated files	install
label-sync	Synchronize labels across organizations	install
license-header-lint	PR checker that ensures that source files contain valid license headers	install
merge-on-green	Merge a pull-request when all required checks have passed	install
policy	Check repo configuration against known rules	install
release-please	Proposes releases based on semantic version commits	install
release-trigger	Trigger releases jobs	install
repo-metadata-lint	Lint .repo-metadata.json files	install
snippet-bot	Check for mismatched region tags in PRs	install
sync-repo-settings	Synchronize repository settings from a centralized config	install
trusted-contribution	Allows Kokoro CI to trigger for trusted contributors	install

https://github.com/googleapis/repo-automation-bots


QUESTIONS
FOUND IN GOOGLE AUTOCOMPLETE
WHY DO WHALES JUMP
WHY ARE WITCHES GREEN
WHY ARE THERE MIRRORS ABOVE BEDS
WHY DO I SAY UH
WHY IS SEA SALT BETTER
WHY ARE THERE TREES IN THE MIDDLE OF FIELDS
WHY IS THERE NOT A POKEMON MMO
WHY IS THERE LAUGHING IN TV SHOWS
WHY ARE THERE DOORS ON THE FREEWAY
WHY ARE THERE SO MANY SYCHOSTICKS RUNNING
WHY AREN'T THERE ANY COUNTRIES IN ANTARCTICA
WHY ARE THERE SCARY SOUNDS IN MINECRAFT
WHY IS THERE KICKING IN MY STOMACH
WHY ARE THERE TWO SLASHES AFTER HTTP
WHY ARE THERE CELEBRITIES
WHY DO SNAKES EXIST
WHY DO OYSTERS HAVE PEARLS
WHY ARE DUCKS CALLED DUCKS
WHY DO THEY CALL IT THE CLAP
WHY ARE KYLE AND CARTMAN FRIENDS
WHY IS THERE AN ARROW ON AANG'S HEAD
WHY ARE TEXT MESSAGES BLUE
WHY ARE THERE MUSTACHES ON CLOTHES
WHY ARE THERE MUSTACHES ON CARS
WHY ARE THERE MUSTACHES EVERYWHERE
WHY ARE THERE SO MANY BIRDS IN OHIO
WHY IS THERE SO MUCH RAIN IN OHIO
WHY IS OHIO WEATHER SO WEIRD
WHY ARE THERE MALE AND FEMALE BIKES
WHY ARE THERE BRIDESMAIDS
WHY DO DYING PEOPLE REARM UP
WHY AREN'T THERE VARICOSE AIRBIKES
WHY ARE OLD KLINGONS DIFFERENT
WHY ARE THERE SQUIRRELS
WHY IS PROGRAMMING SO HARD
WHY IS THERE A 0 OHM RESISTOR
WHY DO AMERICANS HATE SOCCER
WHY DO RHYMES SOUND GOOD
WHY DO TREES DIE
WHY IS THERE NO SOUND ON CNN
WHY AREN'T POKEMON REAL
WHY AREN'T BULLETS SHARP
WHY DO DREAMS SEEM SO REAL
WHY ARE THERE TINY SPIDERS IN MY HOUSE
WHY DO SPIDERS COME INSIDE
WHY ARE THERE HUGE SPIDERS IN MY HOUSE
WHY ARE THERE LOTS OF SPIDERS IN MY HOUSE
WHY ARE THERE SPIDERS IN MY ROOM
WHY ARE THERE SO MANY SPIDERS IN MY ROOM
WHY DO SPIDER BITES ITCH
WHY IS DYING SO SCARY
WHY IS THERE NO GPS IN LAPTOPS
WHY DO KNEES CLICK
WHY AREN'T THERE E GRADES
WHY IS ISOLATION BAD
WHY DO BOYS LIKE ME
WHY DON'T BOYS LIKE ME
WHY IS THERE ALWAYS A JAVA UPDATE
WHY ARE THERE RED DOTS ON MY THIGHS
WHY IS LYING GOOD
WHY DO TESTICLES MOVE
WHY ARE THERE PSYCHICS
WHY ARE HATS SO EXPENSIVE
WHY IS THERE CAFFEINE IN MY SHAMPOO
WHY DO YOUR BOOBS HURT
WHY ARE THERE SLAVES IN THE BIBLE
WHY DO TWINS HAVE DIFFERENT FINGERPRINTS
WHY ARE AMERICANS AFRAID OF DRAGONS
WHY IS HTTPS CROSSED OUT IN RED
WHY IS THERE A LINE THROUGH HTTPS
WHY IS THERE A RED LINE THROUGH HTTPS ON FACEBOOK
WHY IS HTTPS IMPORTANT
WHY AREN'T MY ARMS GROWING
WHY IS YKK ON ALL ZIPPERS
WHY ARE THERE WEEKS
WHY DO I FEEL DIZZY
WHY DO IGUANAS DIE
WHY AREN'T ECONOMISTS RICH
WHY DO AMERICANS CALL IT SOCCER
WHY ARE MY EARS RINGING
WHY ARE THERE SO MANY AVENGERS
WHY ARE THE AVENGERS FIGHTING THE X MEN
WHY IS WOLVERINE NOT IN THE AVENGERS
WHY ARE THERE SWARMS OF GNATS
WHY IS THERE PHLEGM
WHY ARE THERE SO MANY CROWS IN ROCHESTER, MN
WHY IS PSYCHIC WEAK TO BUG
WHY DO CHILDREN GET CANCER
WHY IS POSEIDON ANGRY WITH ODYSSEUS
WHY IS THERE ICE IN SPACE
WHY IS THERE LAVA
WHY ARE THERE ANTS IN MY LAPTOP
WHY IS EARTH TILTED
WHY IS SPACE BLACK
WHY IS OUTER SPACE SO COLD
WHY ARE THERE PYRAMIDS ON THE MOON
WHY IS NASA SHUTTING DOWN
WHY ARE THERE GHOSTS
WHY IS THERE AN OWL IN MY BACKYARD
WHY IS THERE AN OWL OUTSIDE MY WINDOW
WHY IS THERE AN OWL ON THE DOLLAR BILL
WHY DO OWLS ATTACK PEOPLE
WHY ARE AK 47s SO EXPENSIVE
WHY ARE THERE HELICOPTERS CIRCLING MY HOUSE
WHY ARE THERE GODS
WHY ARE THERE TWO SPOOKS
WHY IS MT VESUVIUS THERE
WHY DO THEY SAY T MINUS
WHY ARE THERE OBELISKS
WHY ARE WRESTLERS ALWAYS WET
WHY ARE OCEANS BECOMING MORE ACIDIC
WHY IS ARWEN DYING
WHY AREN'T MY QUAIL LAYING EGGS
WHY AREN'T MY QUAIL EGGS HATCHING
WHY AREN'T THERE ANY FOREIGN MILITARY BASES IN AMERICA
WHY IS SEX SO IMPORTANT
WHY ARE MY BOOBS ITCHY
WHY ARE CIGARETTES LEGAL
WHY ARE THERE DUCKS IN MY POOL
WHY IS JESUS WHITE
WHY IS THERE LIQUID IN MY EAR
WHY DO Q TIPS FEEL GOOD
WHY DO GOOD PEOPLE DIE
WHY AREN'T THERE GUNS IN HARRY POTTER
WHY ARE ULTRASOUNDS IMPORTANT
WHY ARE ULTRASOUND MACHINES EXPENSIVE
WHY IS STEALING WRONG
WHY ARE DOGS AFRAID OF FIREWORKS
WHY IS THERE NO KING IN ENGLAND
WHY IS LIFE SO BORING
WHY IS GPS FREE
WHY ARE THERE FEMALE MR MIMES
WHY IS THERE HELL IF GOD FORGIVES
WHY AREN'T THERE DINOSAUR GHOSTS